

Controles client-side y validacion del servidor

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

JavaScript, campos hidden, botones deshabilitados, validaciones HTML y datos almacenados en el navegador mejoran la interfaz, pero el cliente controla la petición final. El servidor debe repetir validación, autenticación y autorización sobre cada operación.

Burp o curl permiten omitir la interfaz y cambiar parámetros, métodos, cookies y cuerpos. Si el backend confía en `role=admin`, `price`, `user_id` o una comprobación hecha solo en JavaScript, el control se puede saltar.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

Cuando la interfaz oculta acciones, limita valores o decide permisos antes de enviar una petición al backend.

Cómo identificarla

- hidden
- disabled
- localStorage
- role
- price
- user_id
- Validación JavaScript

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

Captura una petición válida, cambia una sola propiedad controlada por el cliente y compara la respuesta con otra cuenta o rol.

Evidencia esperada: Evidencia reproducible de que el servidor acepta o rechaza correctamente el cambio, separada del comportamiento visual del navegador.

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.
3. Define la primitiva mínima indicada por la fuente.
4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

```
curl -i "$URL/profile?user_id=1001" -H "Cookie: session=$COOKIE"
```

Objetivo y contexto: Reproduce directamente una petición autenticada para comprobar si el servidor valida la propiedad del recurso.

Resultado esperado: Un 403 confirma control; datos de otra cuenta confirman un fallo de autorización.

Anatomía de los payloads

La primera prueba es `curl -i "$URL/profile?user_id=1001" -H "Cookie: session=$COOKIE"`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

Evidencia reproducible de que el servidor acepta o rechaza correctamente el cambio, separada del comportamiento visual del navegador.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Observa la petición real.
- Identifica el dato que impone la UI.
- Repite en Repeater.
- Cambia solo ese dato.
- Compara por cuenta, status y cuerpo.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- Cambiar la interfaz sin conseguir una respuesta distinta del servidor no demuestra impacto.
- Un 403 consistente al repetir la petición indica que el backend sí aplica el control.

- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

Todo valor controlado por el navegador puede modificarse; la seguridad real debe imponerse en el servidor. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y preconditiones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.

4. Interpretar señal antes de escalar.
5. Guardar evidencia y mitigación.

Referencias

- Concepto fuente de THM Fieldbook (client-side-controls)
- Referencia técnica externa

Navegación

Anterior: Construcción de payloads. Índice: curso. Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.